



COMPTE RENDU

DROIT





SOMMAIRE

I. MISE EN PLACE DE L'ORGANISATION DE LA CONFORMITÉ

- 1. DÉSIGNATION D'UN DÉLÉGUÉ À LA PROTECTION DES DONNÉES (DPO)
- 2. CRÉATION DU REGISTRE DES ACTIVITÉS DE TRAITEMENT

II. NETTOYAGE ET CORRECTION DES DONNÉES TRAITÉES

- 1. APPLICATION DU PRINCIPE DE MINIMISATION

III. DÉFINITION DES DURÉES DE CONSERVATION

- 1. DURÉES DE CONSERVATION DES DONNÉES
- 2. PROCÉDURE D'ARCHIVAGE ET DE SUPPRESSION AUTOMATIQUE

IV. MISE EN PLACE DES MESURES DE SÉCURITÉ

- 1. MESURES TECHNIQUES
- 2. MESURES ORGANISATIONNELLES

V. INFORMATION DES SALARIÉS ET RESPECT DE LEURS DROITS

- 1. OBLIGATION D'INFORMATION
- 2. EXERCICE DES DROITS

VI. ÉVALUATION DES RISQUES (AIPD)

VII. PLAN D'ACTION PRIORITAIRE

- A. ACTIONS IMMÉDIATES (SEMAINE 1 À 2)
- B. ACTIONS À COURT TERME (1 À 2 MOIS)
- C. ACTIONS À MOYEN TERME (3 À 6 MOIS)

CONCLUSION



MISE EN CONFORMITÉ RGPD DU SERVICE RESSOURCES HUMAINES

CONTEXTE GÉNÉRAL

L'ENTREPRISE INDUSTRIELLE DANS LAQUELLE NOUS INTERVENONS COMPTE UNE CENTAINE DE SALARIÉS. DEPUIS L'ENTRÉE EN VIGUEUR DU RÈGLEMENT GÉNÉRAL SUR LA PROTECTION DES DONNÉES (RGPD) LE 25 MAI 2018, AUCUNE ACTION N'A ÉTÉ MENÉE POUR SE METTRE EN CONFORMITÉ, EN PARTICULIER AU SEIN DU SERVICE DES RESSOURCES HUMAINES.

CE SERVICE MANIPULE POURTANT DES INFORMATIONS SENSIBLES ET VOLUMINEUSES SUR LES SALARIÉS : IDENTITÉ, COORDONNÉES PERSONNELLES, DONNÉES DE SANTÉ, PARCOURS PROFESSIONNEL, ÉLÉMENTS DE RÉMUNÉRATION, ETC.

LE NON-RESPECT DU RGPD EXPOSE L'ENTREPRISE À DE LOURDES CONSÉQUENCES : DES AMENDES POUVANT ATTEINDRE 20 MILLIONS D'EUROS OU 4 % DU CHIFFRE D'AFFAIRES ANNUEL MONDIAL, DES SANCTIONS PÉNALES, MAIS AUSSI UN PRÉJUDICE D'IMAGE IMPORTANT EN CAS DE PUBLICATION D'UNE MISE EN DEMEURE PAR LA CNIL. L'OBJECTIF DE CE PLAN EST DONC DE PROPOSER DES MESURES CONCRÈTES, COMPRÉHENSIBLES PAR LA DIRECTION, AFIN D'ASSURER UNE MISE EN CONFORMITÉ RAPIDE ET DURABLE DU SERVICE RH.

I. MISE EN PLACE DE L'ORGANISATION DE LA CONFORMITÉ

I. DÉSIGNATION D'UN DÉLÉGUÉ À LA PROTECTION DES DONNÉES (DPO)

MÊME SI L'ENTREPRISE COMPTE MOINS DE 250 SALARIÉS, LA DÉSIGNATION D'UN DÉLÉGUÉ À LA PROTECTION DES DONNÉES (DPO) EST FORTEMENT RECOMMANDÉE. CETTE DÉSIGNATION PEUT MÊME DEVENIR OBLIGATOIRE DANS LA MESURE OÙ LE SERVICE RH TRAITE CERTAINES DONNÉES SENSIBLES, NOTAMMENT DES INFORMATIONS RELATIVES À LA SANTÉ DES SALARIÉS LORS DES VISITES MÉDICALES. LE DPO AURA POUR MISSIONS :

- D'INFORMER ET DE CONSEILLER LA DIRECTION SUR SES OBLIGATIONS EN MATIÈRE DE PROTECTION DES DONNÉES,
- DE CONTRÔLER LA CONFORMITÉ DES TRAITEMENTS AU RGPD,
- DE SERVIR D'INTERLOCUTEUR DIRECT AVEC LA CNIL,
- ET DE SENSIBILISER RÉGULIÈREMENT LES ÉQUIPES AUX BONNES PRATIQUES.

LE DPO DOIT DISPOSER DE COMPÉTENCES JURIDIQUES ET TECHNIQUES SOLIDES, AGIR DE MANIÈRE INDÉPENDANTE ET ÊTRE LIBRE DE TOUT CONFLIT D'INTÉRÊTS.
S'IL N'EXISTE PAS DE PROFIL ADAPTÉ EN INTERNE, L'ENTREPRISE POURRA RECOURIR À UN **PRESTATAIRE EXTERNE**.

2. CRÉATION DU REGISTRE DES ACTIVITÉS DE TRAITEMENT

L'ENTREPRISE DOIT TENIR À JOUR UN **REGISTRE DES ACTIVITÉS DE TRAITEMENT**, DOCUMENT CENTRAL EXIGÉ PAR L'ARTICLE 30 DU RGPD.

CE REGISTRE RECENSERA L'ENSEMBLE DES TRAITEMENTS DE DONNÉES RÉALISÉS PAR LE SERVICE RH, NOTAMMENT :

1. LA GESTION DE LA PAIE,
2. LA GESTION DE CARRIÈRE ET DE LA FORMATION,
3. LE SUIVI DES VISITES MÉDICALES,
4. LE RECRUTEMENT,
5. L'ÉVALUATION PROFESSIONNELLE.

POUR CHAQUE TRAITEMENT, LA FICHE DU REGISTRE PRÉCISERA :

- LA FINALITÉ (L'OBJECTIF POURSUIVI),
- LES CATÉGORIES DE PERSONNES CONCERNÉES (SALARIÉS, CANDIDATS),
- LES CATÉGORIES DE DONNÉES COLLECTÉES,
- LES DESTINATAIRES INTERNES ET EXTERNES (PRESTATAIRES, ORGANISMES SOCIAUX, ETC.),
- LA DURÉE DE CONSERVATION,
- LES MESURES DE SÉCURITÉ MISES EN PLACE,
- ET, LE CAS ÉCHÉANT, LES TRANSFERTS DE DONNÉES HORS UNION EUROPÉENNE.

CE REGISTRE CONSTITUE LA **PREUVE DE CONFORMITÉ** LA PLUS IMPORTANTE EN CAS DE CONTRÔLE PAR LA CNIL.

II. NETTOYAGE ET CORRECTION DES DONNÉES TRAITÉES

I. APPLICATION DU PRINCIPE DE MINIMISATION

LE PRINCIPE DE MINIMISATION IMPOSE DE NE COLLECTER ET DE NE CONSERVER QUE LES DONNÉES STRICTEMENT NÉCESSAIRES À LA FINALITÉ POURSUIVIE.

UN AUDIT COMPLET DES FICHIERS RH A PERMIS D'IDENTIFIER PLUSIEURS DONNÉES **NON PERTINENTES OU ILLÉGALES**, QUI DOIVENT ÊTRE SUPPRIMÉES IMMÉDIATEMENT.

LES INFORMATIONS SUIVANTES DOIVENT ÊTRE **EFFACÉES** :

- LA **NATURE DES ÉTUDES SUIVIES PAR LES ENFANTS**,
- LA **PROFESSION DES PARENTS DE L'EMPLOYÉ**.

CES DONNÉES N'ONT AUCUN LIEN DIRECT AVEC LA GESTION DU PERSONNEL ET NE PEUVENT DONC PAS ÊTRE CONSERVÉES.

CERTAINES DONNÉES DITES **SENSIBLES** NÉCESSITENT UNE RÉGULARISATION IMMÉDIATE :

- L'**APPARTENANCE SYNDICALE** NE PEUT ÊTRE ENREGISTRÉE QUE DANS UN CADRE LÉGAL STRICT (PAR EXEMPLE POUR LES ÉLECTIONS PROFESSIONNELLES) ET AVEC LE **CONSENTEMENT EXPLICITE** DE LA PERSONNE.
- LE **NOMBRE DE JOURS DE GRÈVE SUR LES DIX DERNIÈRES ANNÉES** CONSTITUE UNE INFORMATION DISCRIMINATOIRE ET DOIT ÊTRE **SUPPRIMÉ SANS DÉLAI**.
- LES **PATHOLOGIES DES SALARIÉS**, RELEVANT DU SECRET MÉDICAL, **NE DOIVENT JAMAIS ÊTRE CONSERVÉES PAR LE SERVICE RH**. SEUL LE MÉDECIN DU TRAVAIL PEUT DÉTENIR CES INFORMATIONS ; LE SERVICE RH NE DOIT CONNAÎTRE QUE LES AVIS D'APTITUDE, D'INAPTITUDE ET LES PROPOSITIONS D'AMÉNAGEMENT.

PAR AILLEURS, D'AUTRES DONNÉES, BIEN QUE LÉGITIMES, DOIVENT ÊTRE **ENCADRÉES** :

- LES TAUX D'INVALIDITÉ OU LA RECONNAISSANCE RQTH DOIVENT ÊTRE TRAITÉS AVEC LA PLUS GRANDE CONFIDENTIALITÉ ET ACCESSIBLES UNIQUEMENT AU PERSONNEL HABILITÉ.
- LES COORDONNÉES PERSONNELLES NE DOIVENT ÊTRE UTILISÉES QU'EN CAS D'URGENCE.
- LA PHOTOGRAPHIE DU SALARIÉ PEUT ÊTRE UTILISÉE POUR LES BADGES OU L'INTRANET, MAIS SON UTILISATION EXTERNE (SITE WEB, BROCHURES) NÉCESSITE UN **CONSENTEMENT ÉCRIT**

III. DÉFINITION DES DURÉES DE CONSERVATION

LES DONNÉES PERSONNELLES NE DOIVENT JAMAIS ÊTRE CONSERVÉES INDÉFINIMENT. CHAQUE CATÉGORIE DOIT AVOIR UNE **DURÉE DE CONSERVATION CLAIREMENT DÉFINIE**, CONFORME AUX TEXTES ET AUX RECOMMANDATIONS DE LA CNIL.

- DOSSIER DU SALARIÉ ACTIF : PENDANT TOUTE LA DURÉE DU CONTRAT DE TRAVAIL
- JUSTIFICATION : NÉCESSITÉ OPÉRATIONNELLE
- DOSSIER APRÈS DÉPART : 5 ANS APRÈS LE DÉPART - JUSTIFICATION :
PRESCRIPTION CIVILE
- BULLETINS DE PAIE : 5 ANS APRÈS LE DÉPART - JUSTIFICATION : OBLIGATIONS
LÉGALES
- CANDIDATURES NON RETENUES : 2 ANS APRÈS LE DERNIER CONTACT -
JUSTIFICATION : DÉFENSE EN CAS DE LITIGE
- ÉVALUATIONS PROFESSIONNELLES : DURÉE DE PRÉSENCE + 5 ANS -
JUSTIFICATION : PREUVE EN CAS DE CONTENTIEUX
- REGISTRE DES ACCIDENTS DU TRAVAIL : 5 ANS - JUSTIFICATION : OBLIGATION
LÉGALE
- VISITES MÉDICALES (AVIS D'APTITUDE) : DURÉE DE PRÉSENCE + 5 ANS -
JUSTIFICATION : RISQUES DE LITIGE RH

UNE PROCÉDURE **D'ARCHIVAGE ET DE SUPPRESSION AUTOMATIQUE** DOIT ÊTRE INSTAURÉE AFIN D'ÉVITER TOUTE CONSERVATION ABUSIVE.

IV. MISE EN PLACE DES MESURES DE SÉCURITÉ

I. MESURES TECHNIQUES

POUR ASSURER LA PROTECTION DES DONNÉES RH, PLUSIEURS ACTIONS TECHNIQUES SONT INDISPENSABLES :

- LES **DROITS D'ACCÈS** DOIVENT ÊTRE STRICTEMENT DÉFINIS SELON LES FONCTIONS : SEULS LES COLLABORATEURS AUTORISÉS PEUVENT CONSULTER OU MODIFIER LES FICHIERS RH.
- LES **MOTS DE PASSE** DOIVENT ÊTRE ROBUSTES (AU MOINS 12 CARACTÈRES, MÉLANGE DE CHIFFRES, LETTRES ET SYMBOLES), INDIVIDUELS, ET RENOUVELÉS RÉGULIÈREMENT.
- LES **POSTES INFORMATIQUES** DOIVENT ÊTRE SÉCURISÉS : VERROUILLAGE AUTOMATIQUE APRÈS 5 MINUTES D'INACTIVITÉ, ANTIVIRUS ET PARE-FEU À JOUR, CHIFFREMENT DES ORDINATEURS PORTABLES.
- LA **TRAÇABILITÉ DES ACCÈS** DOIT ÊTRE ASSURÉE GRÂCE À DES JOURNAUX (LOGS) PERMETTANT D'IDENTIFIER QUI A CONSULTÉ OU MODIFIÉ UNE DONNÉE. CES LOGS DOIVENT ÊTRE CONSERVÉS PENDANT SIX MOIS AU MINIMUM.
- DES **SAUVEGARDES CHIFFRÉES ET RÉGULIÈRES** DOIVENT ÊTRE RÉALISÉES, TESTÉES ET STOCKÉES SUR UN SITE SÉCURISÉ OU UN COFFRE-FORT NUMÉRIQUE.

2. MESURES ORGANISATIONNELLES

SUR LE PLAN ORGANISATIONNEL, L'ENTREPRISE DOIT :

- **FORMER L'ENSEMBLE DE L'ÉQUIPE RH** AUX PRINCIPES DU RGPD ET À LA GESTION SÉCURISÉE DES DONNÉES.
- METTRE EN PLACE UNE **CHARTÉ INFORMATIQUE** SIGNÉE PAR TOUS LES SALARIÉS.
- DOCUMENTER TOUS LES PROCESSUS DE TRAITEMENT (COLLECTE, STOCKAGE, SUPPRESSION).
- CRÉER DES **PROCÉDURES INTERNES** POUR LA GESTION DES INCIDENTS DE SÉCURITÉ ET POUR LE TRAITEMENT DES DEMANDES D'EXERCICE DES DROITS (ACCÈS, RECTIFICATION, EFFACEMENT, ETC.).
- **ENCADRER LES SOUS-TRAITANTS** EN SIGNANT DES CONTRATS CONFORMES À L'ARTICLE 28 DU RGPD, INCLUANT LES CLAUSES DE CONFIDENTIALITÉ, DE SÉCURITÉ ET D'ASSISTANCE EN CAS DE VIOLATION.

V. INFORMATION DES SALARIÉS ET RESPECT DE LEURS DROITS

I. OBLIGATION D'INFORMATION

LES SALARIÉS DOIVENT ÊTRE **INFORMÉS DE MANIÈRE CLAIRE ET TRANSPARENTE** SUR LE TRAITEMENT DE LEURS DONNÉES :

- DÈS LEUR EMBAUCHE,
- À CHAQUE NOUVELLE COLLECTE,
- ET À CHAQUE MODIFICATION DE FINALITÉ.

UNE **NOTICE D'INFORMATION RGPD** DOIT LEUR ÊTRE REMISE OU MISE À DISPOSITION SUR L'INTRANET.

CETTE NOTICE PRÉCISERA L'IDENTITÉ DU RESPONSABLE DE TRAITEMENT, LES FINALITÉS, LA BASE LÉGALE, LES DESTINATAIRES, LA DURÉE DE CONSERVATION, LES DROITS DONT DISPOSENT LES SALARIÉS ET LES COORDONNÉES DU DPO.

2. EXERCICE DES DROITS

CHAQUE SALARIÉ DISPOSE DE PLUSIEURS DROITS :

- **DROIT D'ACCÈS** : OBTENIR UNE COPIE DE SES DONNÉES,
- **DROIT DE RECTIFICATION** : CORRIGER LES ERREURS,
- **DROIT À L'EFFACEMENT** : DEMANDER LA SUPPRESSION DE DONNÉES DEVENUES INUTILES,
- **DROIT D'OPPOSITION** : REFUSER CERTAINS TRAITEMENTS NON OBLIGATOIRES,
- **DROIT À LA LIMITATION** : GELER TEMPORAIREMENT UN TRAITEMENT,
- **DROIT À LA PORTABILITÉ** : RÉCUPÉRER SES DONNÉES DANS UN FORMAT EXPLOITABLE.

UNE **PROCÉDURE INTERNE** DEVRA PERMETTRE DE RÉPONDRE À CES DEMANDES **DANS UN DÉLAI D'UN MOIS**, CONFORMÉMENT AU RGPD.

VI. ÉVALUATION DES RISQUES (AIPD)

UNE **ANALYSE D'IMPACT RELATIVE À LA PROTECTION DES DONNÉES (AIPD)** DOIT ÊTRE ENVISAGÉE SI CERTAINS TRAITEMENTS RH PRÉSENTENT UN RISQUE ÉLEVÉ POUR LES DROITS ET LIBERTÉS DES PERSONNES.

CELA PEUT CONCERNER :

- L'UTILISATION D'OUTILS DE SURVEILLANCE OU DE CONTRÔLE DES SALARIÉS,
- LE TRAITEMENT MASSIF DE DONNÉES DE SANTÉ,
- OU DES TRAITEMENTS AUTOMATISÉS D'ÉVALUATION DU PERSONNEL.

LE DPO VÉRIFIERA LA NÉCESSITÉ D'UNE AIPD ET ACCOMPAGNERA LE SERVICE RH DANS SA RÉALISATION.

VII. PLAN D'ACTION PRIORITAIRE

A. ACTIONS IMMÉDIATES (SEMAINE 1 À 2)

- SUPPRESSION DES DONNÉES ILLÉGALES : NOMBRE DE JOURS DE GRÈVE, PATHOLOGIES, PROFESSION DES PARENTS, ÉTUDES DES ENFANTS.
- RESTRICTION DES ACCÈS AUX SEULS COLLABORATEURS HABILITÉS.
- NOMINATION D'UN **RÉFÉRENT RGPD** TEMPORAIRE POUR COORDONNER LES ACTIONS.
-

B. ACTIONS À COURT TERME (1 À 2 MOIS)

- DÉSIGNATION OFFICIELLE DU DPO.
- CRÉATION DU **REGISTRE DES TRAITEMENTS RH**.
- RÉDACTION ET DIFFUSION DE LA NOTICE **D'INFORMATION RGPD**.
- DÉFINITION DES **DURÉES DE CONSERVATION** ET MISE EN PLACE DES PROCÉDURES D'ARCHIVAGE.
- ADOPTION D'UNE **POLITIQUE DE MOTS DE PASSE** ET DE SÉCURITÉ INTERNE.

C. ACTIONS À MOYEN TERME (3 À 6 MOIS)

- DÉPLOIEMENT COMPLET DES MESURES TECHNIQUES : CHIFFREMENT, LOGS, VERROUILLAGE, SAUVEGARDES.
- FORMATION DE L'ÉQUIPE RH ET SENSIBILISATION DU PERSONNEL.
- AUDIT DE CONFORMITÉ DES CONTRATS AVEC LES PRESTATAIRES (PAIE, SIRH, RECRUTEMENT).
- VÉRIFICATION DE LA NÉCESSITÉ D'UNE AIPD POUR CERTAINS TRAITEMENTS.

CONCLUSION

LA MISE EN CONFORMITÉ DU SERVICE RH AVEC LE RGPD EST UNE DÉMARCHE PRIORITAIRE QUI PERMETTRA À L'ENTREPRISE :

- DE **SE PROTÉGER JURIDIQUEMENT** CONTRE LES SANCTIONS FINANCIÈRES,
- DE **SÉCURISER LES DONNÉES PERSONNELLES** DE SES SALARIÉS,
- DE **RENFORCER LA CONFIANCE** AU SEIN DU PERSONNEL,
- ET DE **PROFESSIONNALISER LA GESTION DES RESSOURCES HUMAINES.**

UNE FOIS LE DPO DÉSIGNÉ, IL ASSURERA LE SUIVI DU PLAN D'ACTION, LA VÉRIFICATION CONTINUE DES TRAITEMENTS ET L'EXTENSION PROGRESSIVE DE LA CONFORMITÉ AUX AUTRES SERVICES DE L'ENTREPRISE.



PROJET RÉALISÉ PAR :

ROCA --LABUTTIE JOACKIM

ROBERT TONI

HALLER FABIAN

MISERY RÉMI

SIMIAN NATHAN

